

Intrusion Detection Systems

Firewalls are not enough

- Don't solve the real problems
 - Buggy software (think buffer overflow exploits)
 - Bad protocol design (think WEP in 802.11b)
- Generally don't prevent denial of service
- Passive Devices
 - Firewalls does not have intelligence
 - Limited actions (block, permit)
 - Limited state/history
- Don't prevent insider attacks
- Don't prevent MITM attacks
- Increasing complexity and potential for misconfiguration

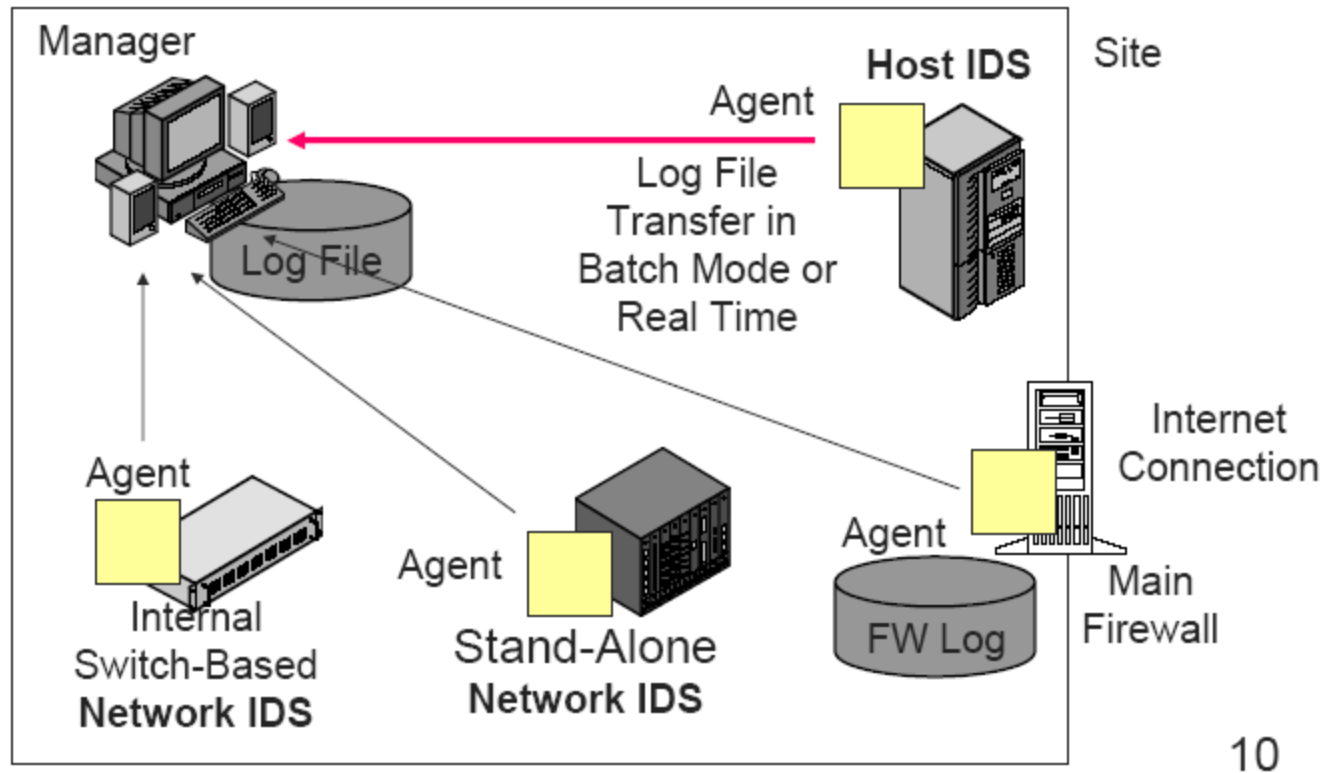
IDS

- More than “Hidden Cameras”
- IDS sensors sniff and analyze traffic searching for various “electronic scent” or “signatures” to identify threats or attempts to exploit vulnerability, and to perform the proper action
- Some types of attacks cannot be detected by examining only host-based data, for instance:
 - Doorknob rattling
 - Masquerading/Spoofing
 - Diversionary attacks
 - Multipronged attacks
 - Chaining
 - Loopback
- IDS analysis
 - **Anomaly-based:** statistical analysis to identify what abnormal traffic or protocol behavior
 - Examples: sudden load increase, flurries of strange IP addresses
 - **Signature-bases:** looking for a pattern in the traffic
 - Examples: scanning, Land attack (source and dest IP are the same) .. Etc

Basic Elements of IDS

Management: Configuration, Tuning	Action: Alarms, Queries, Reports
	Analysis: Attack Signatures and Heuristics
	Logging (Data Collection): Individual Events are Time-Stamped Log is Flat File of Events

Distributed IDS



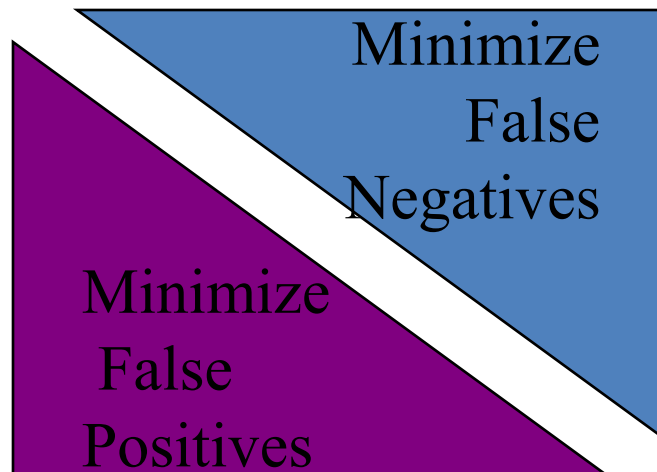
- **Two modes of transfer:**

- Batched (every few minutes)
- Real time (as events occurs or periodically)

- Operations
 - [?] Full protocol analysis
 - [?] Full payload content
- IDSs
 - Event logging in log files
 - Analysis of log file data
 - Alarms
 - false positives (false alarms)
 - Annoyance factor
 - An alarm for a valid but new IP address
 - false negatives (overlooked incidents)
 - More dangerous
 - No alarm for a spoofed IP addresses or stealth port scanning

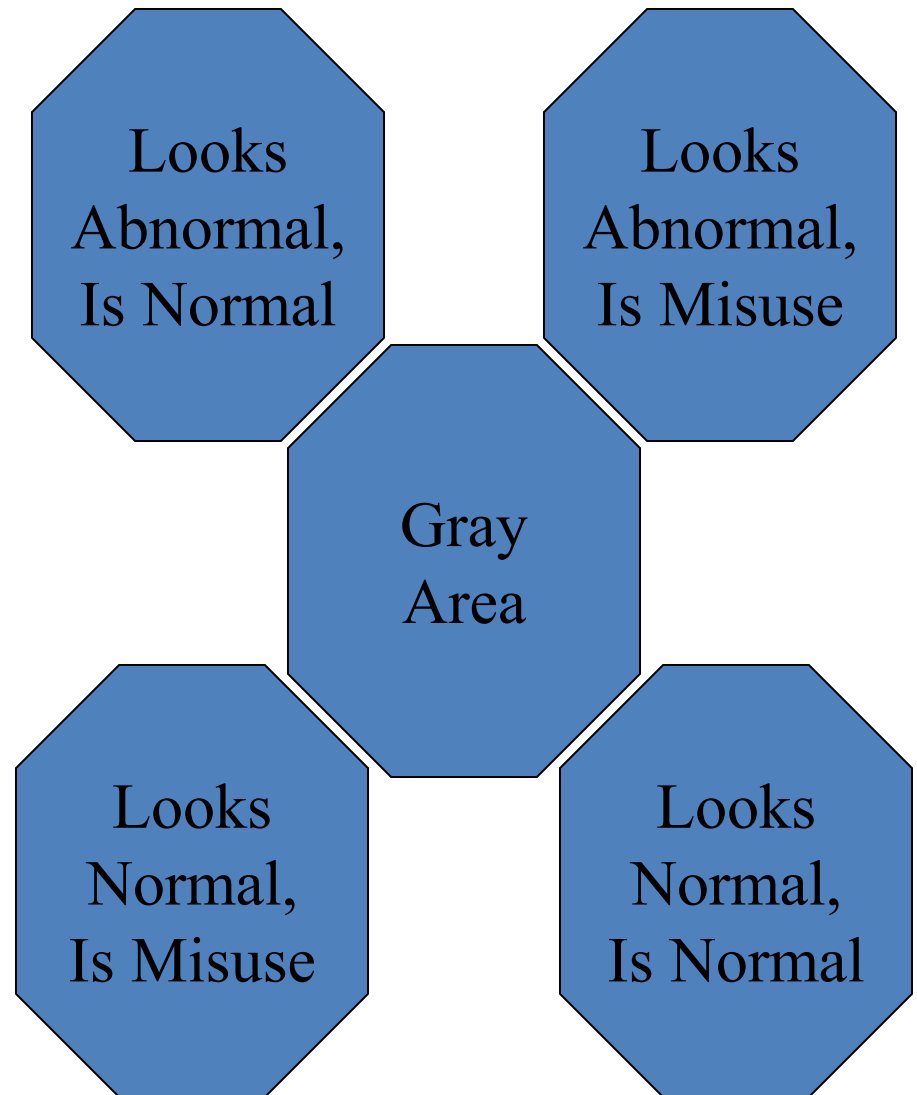
Philosophy/Decisions

- When to “sound an alarm”
- Keep in mind that these are a *continuum*



Decision Results

- We anticipate both false positives and false negatives:
 - **False positive:** some acceptable usage will be diagnosed as misuse
 - **False negative:** some unacceptable usage will be diagnosed as okay



Balancing Issues

- There is an important balance to be reached between these two failures:
 - False positives lead to extra investigatory time, annoyance of users, and perhaps denial of service.
 - False negatives can lead to system damage, undetected misuse.



Managing IDS

- Tuning for precision
 - Too many false positives can overwhelm administrators and dull interest
 - False negatives allow attacks to proceed unseen
 - Tuning for false positives turns off unnecessary rules, reduces alarm levels of unlikely rules
 - IDS might make tuning difficult
- Updates
 - Program and attack signatures must be updated periodically
- Performance
 - If processing speed cannot keep up with network traffic, some packets will not be examined
 - This can make IDSs useless during DoS attacks
 - If memory requirements are too large, system might crash
 - Making logs smaller by saving them more frequently hurts longer-duration event correlation

After Detection – “ReAction”

- Passive
 - Log
 - Alert
- Reactive
 - Log
 - Alert
 - Deal with the attack
 - Instruct router to block incoming traffic from a source IP address

Network IDS (NIDS)

- Capture and analyze packets in promiscuous mode
 - Sensors or Taps on wires
 - Host or Switch or Firewall Sensors
 - Switches and routers have port spanning or port mirroring
 - All traffic incoming and outgoing traffic is sent to manager IDS
- Stand-alone NDIS, single router or switch, does not give global analysis of the network
- Gather and collect data from all sensors and send them to a manager for analysis
 - Real-time analysis
 - After-the-fact analysis
 - Train statistical modeling algorithm on data set – *learning normal to identify abnormal*
 - Bayesian Nets
 - Hidden Markov Models
 - Datamining models
 - Others...
- Records a lot of traffic
 - Very difficult to be discriminating
 - Usually end up recording everything
 - Requires a fair amount of disk space and I/O bandwidth
 - May also require CPU time if there is a lot of traffic and analysis is done in real time
- NDIS cannot filter encrypted payload

Host-based IDS (HIDS)

- Need an IDS for every host
- Collect and analyze packets at host only
- No need to operate in promiscuous mode
- Can examine encrypted payload
 - Look for polymorphic worms
- OS Monitoring
 - events, failed logins, executable changes, system config files (eg., registry, init.conf)
- Application Monitoring
 - Spyware
 - adware
 - Backdoors
 - BO filtering
- McAfee, Symantec, Norton are popular host-based IDS

Intruder



Network-based only

- SYN Flood attack
- Land, Smurf, TearDrop attacks
- BackOrifice hacker tool
- Win Nuke attack

Victim



Host-based only



- Encrypted network traffic
- Overwrite the login executable
- Walk up to the keyboard attack
ex. Sun openPROM



Network-based and Host-based



- 1) Telnet to a system
- 2) Intruder SU's to root
- 3) Turns off logging

- Network IDS
- Host IDS
- Host IDS



- 1) Port scan
- 2) HTTP cgi-bin attack
- 3) Changes a Web page

- Network IDS
- Network IDS
- Host IDS



- 1) Port scan
- 2) Sendmail WIZ attack
- 3) Root Shell Accessed

- Network IDS
- Network IDS
- Host IDS



Popular IDS products

- Commercial
 - Shadow, Cisco, secure, EntraSys, Dragon, ISS Real Secure, and NFR, Symantec, Mcafee, etc
- Open Source
 - Snort, Tripwire
- IDS is a complex system.
 - Outsourcing it is an attractive option

Snort ← NIDS

- Several books written on it
- Very popular
- Uses tcpdump to get network packet info
- Checks each packet against a rule-set
- logs packet information into MySQL backend
- Nice web interface to a BASE engine
 - Analysis Console for Intrusion Database (ACID)

Tripwire ← HIDS

- Records MD5 checksums of critical files and binaries
- Also checks file attributes, i.e. size, dates, permissions, etc...
- Periodically verifies that the files have not been modified
- Good for detecting Rootkit
 - Rootkit
 - After breaking in, attacker wishes to hide her presence
 - Root kit is a set of Trojan binaries (ls, ps, netstat, etc...)
 - Hides files, processes belonging to attacker
 - May also include sniffers to gather username/passwords

IDS Placement

- **Deploy multiple network IDS sensors**
 - Classification: per segment, per traffic, per application
- **Between main firewall and external network**
 - (+) to capture attacks plans
 - (-) exposed IDS to the attack, performance issues, lot of log to view
- **Between main firewall and internal network**
 - (+) to capture all attacks get thru the FW (FW policy problem)
 - (+) IDS less vulnerable to attacks
 - (-) limited view of the attacks (not the planned ones)
- **For high traffic network, the outside IDS identifies the critical server attacks and the inside IDS does protocol and payload detail analysis**
- **At internal network**
 - To detect successful attacks
 - To detect worms and Trojans
 - to detect internal malicious insiders
- **With encryption devices**
 - Place it on the 1st segment that receives the decrypted traffic (could be in the host), or
 - IDS works on the header if not encrypted– limited
- **In switches: make sure it runs on each port**

Good IDS sits on
a separate
network!

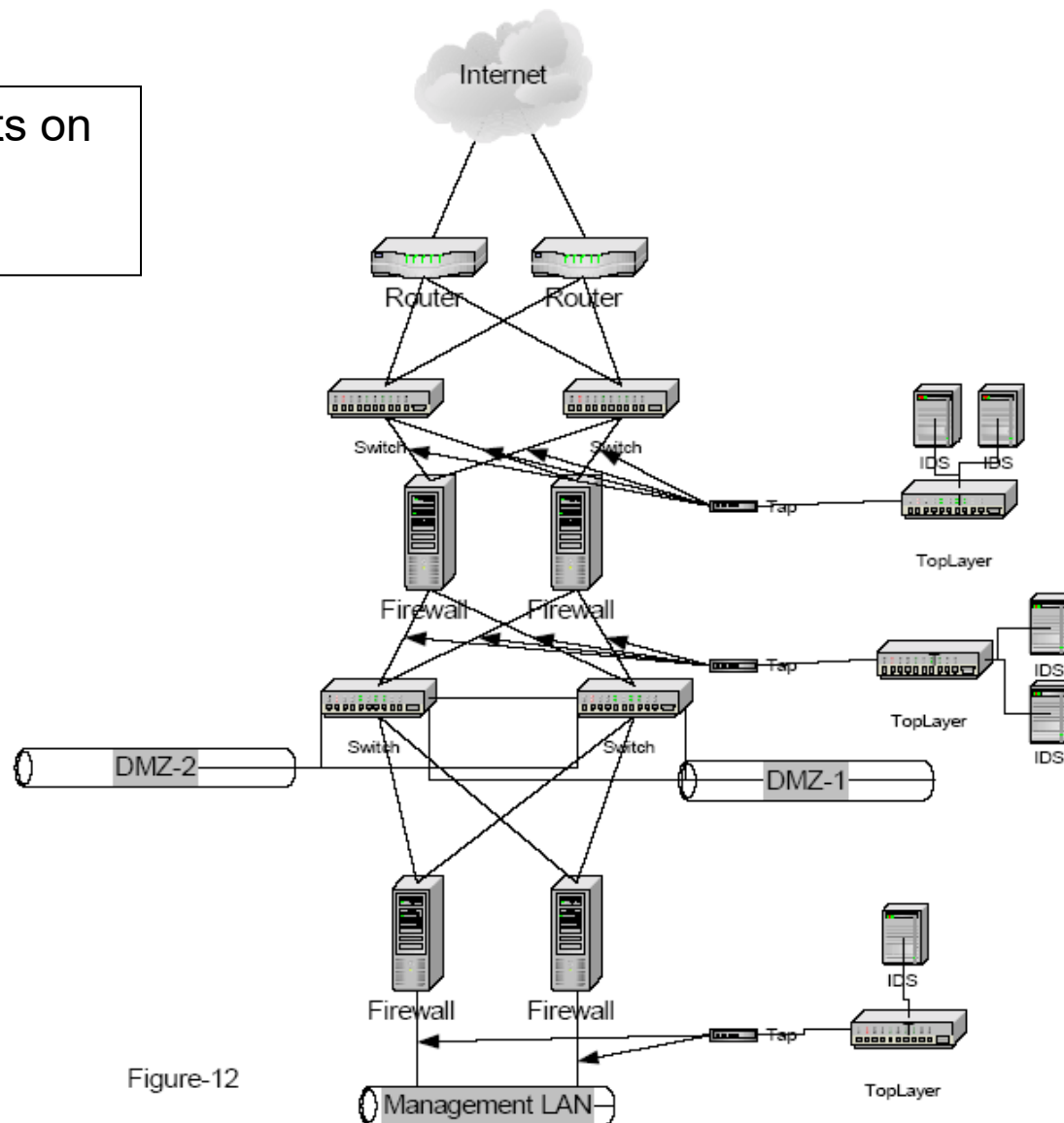
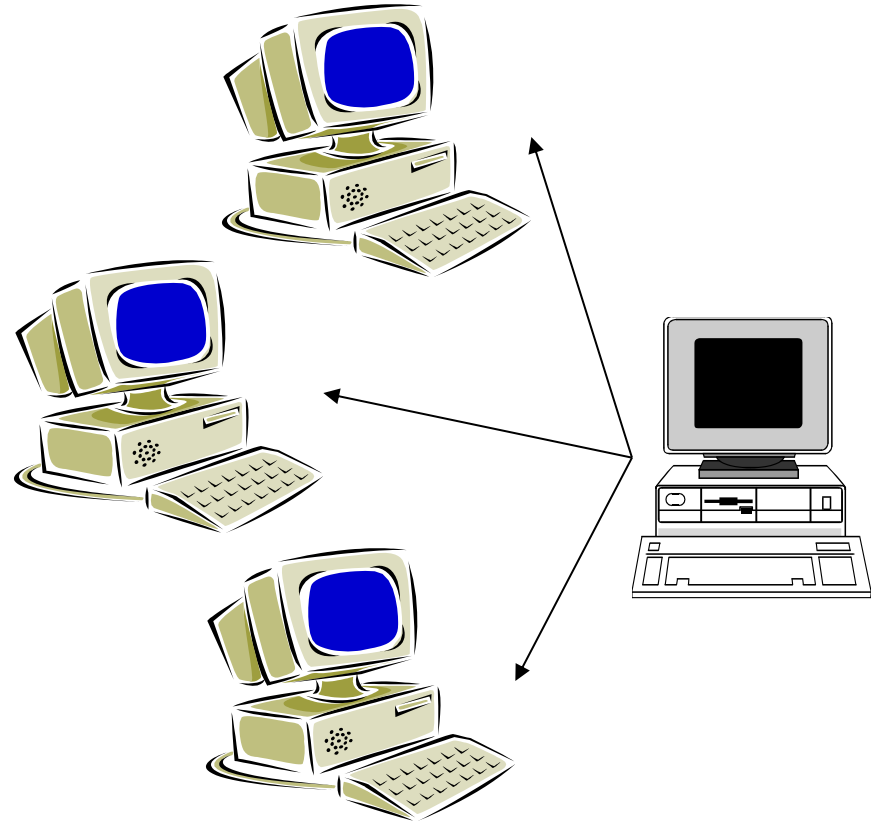


Figure-12

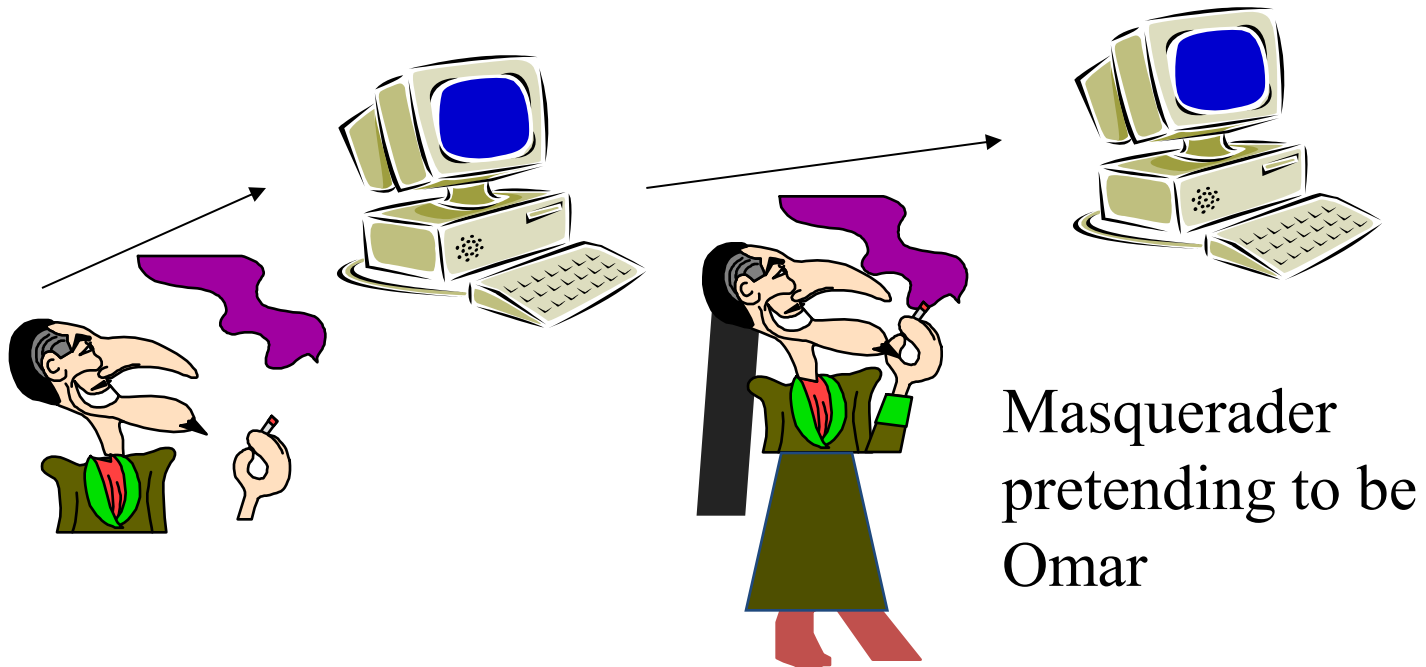
Doorknob Rattling

- **Doorknob rattling:** usually refers to password guessing, but can be used to describe any attack technique where:
 - The intruder undertakes some auditable activity intended to gain access
 - The number of times this activity is attempted is lower than the threshold for the machine being attacked.
 - Attack continues until all targets have been covered and/or access has been gained.



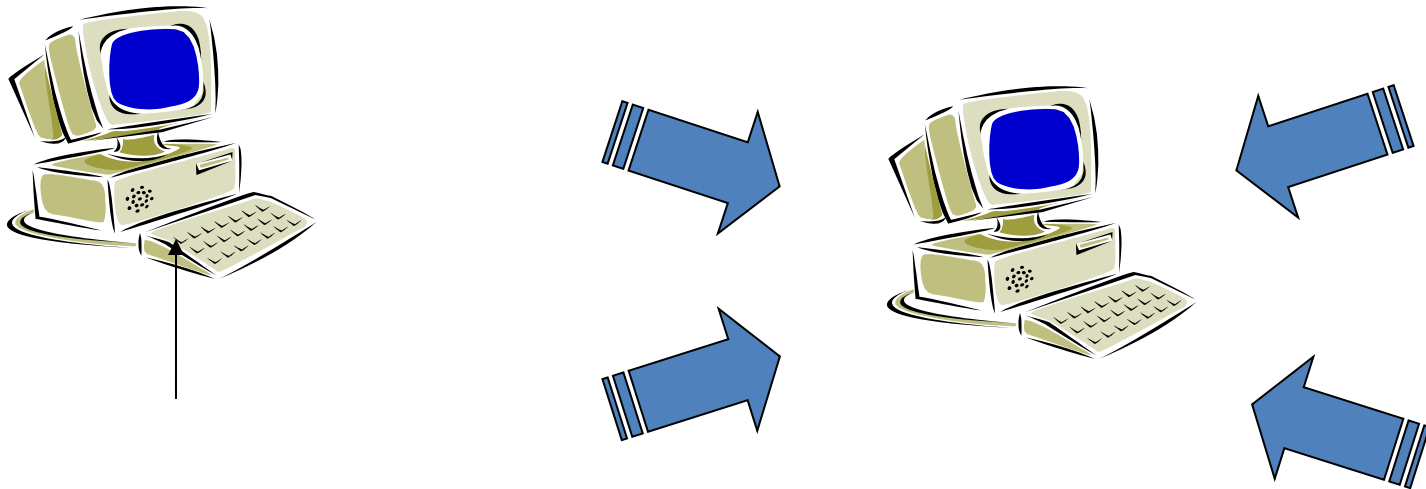
Masquerading/Spoofing

- User enters under one name, then manages “somehow” to change names, or to enter the next system under another name.



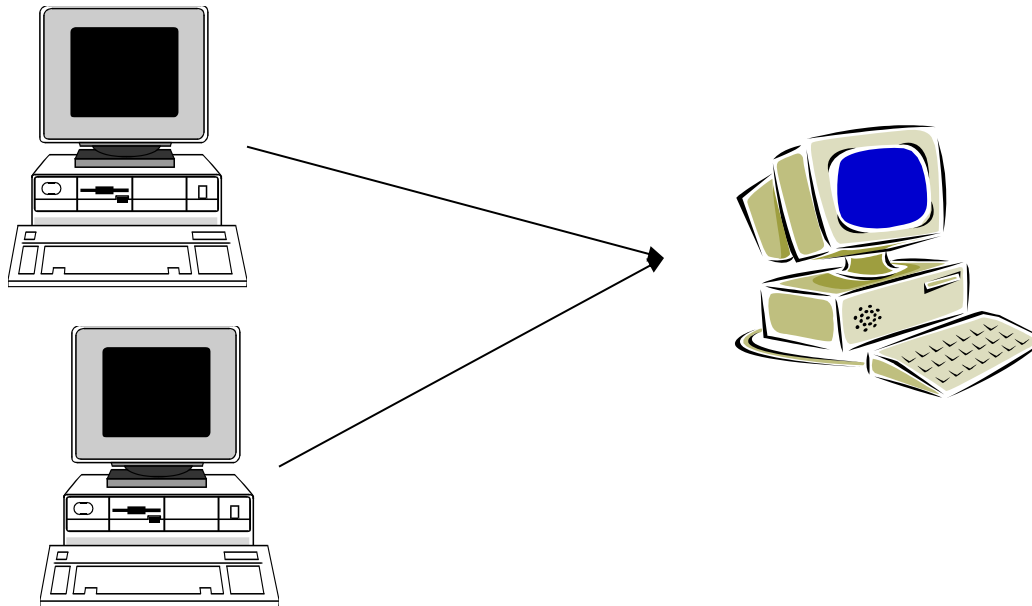
Diversionary Attacks

- One aspect of the attack involves a diversionary or “sidetracking” episode in order to draw attention away from the real target. Often pairs a blatant attack with a subtle attack. Originally uncommon.



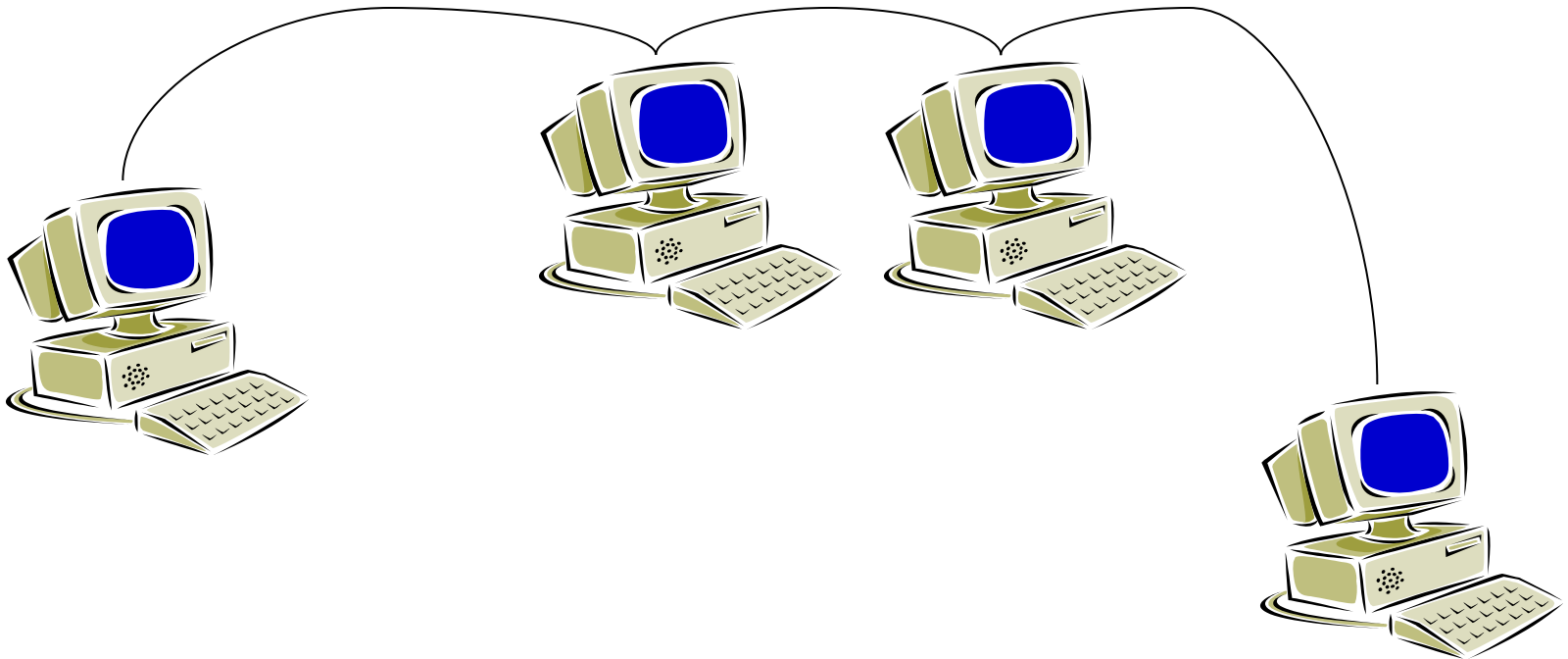
Multipronged Attacks

- Use of multiple sources, perhaps over an extended period of time, to set up and accomplish an attack. Now quite common.
- Similar to DDOS



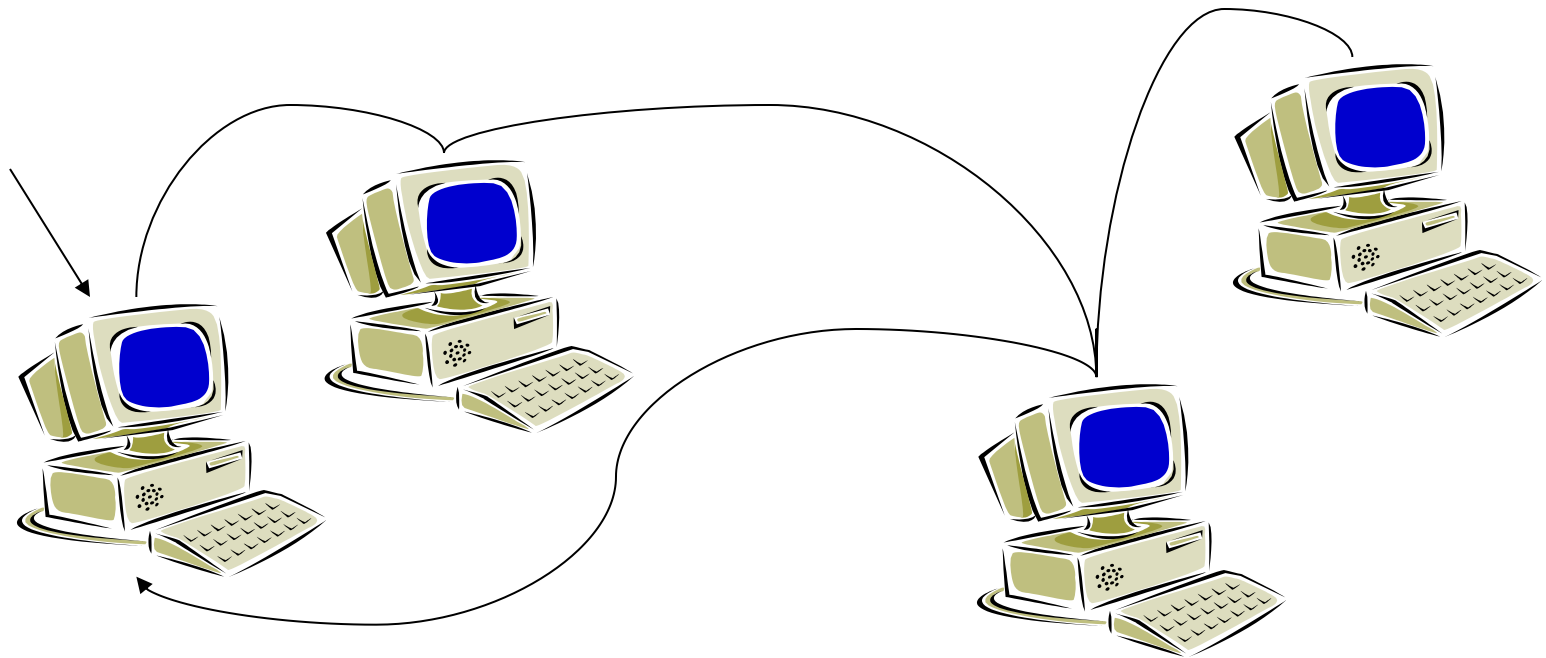
Chaining

- Move from place to place, sometimes with loopbacks, to hide origin and make tracing more difficult.



Loopback

- Like chaining, except that “loops” will be added, sometimes including a change of UID and sometimes not, in order to make tracebacks harder. Loopback can span multiple machines or just one.



Collecting Audit Data

- Audit data generally comes in several different formats, depending on the tools used to collect it. The format, granularity, completeness, and source of the data all affects the kinds of intrusions which can be detected.
- Audit data can be collected at many levels and with many tools. Common examples:
 - Have system tools store data (login, su)
 - Add additional collection at a low system level (Sun BDM)
 - Use “sniffers” to observe data “externally” (network probes, filters on commands such as tcpwrappers)
 - Add auditing to applications

IDS/IPS Classifications

- Signature or misuse detection
 - Anomaly detection
 - Statistical
 - Machine learning
 - Hybrid
-
- *A. Patcha and J-M Park, "An overview of anomaly detection techniques: Existing solutions and latest technological trends," Journal of Computer Networks, 2007.*

Signature-based detection

- Relies on a predefined set of attack signatures
- Examine signatures or sequence of events of incoming packets of known attacks
 - Maintenance and updates of signatures dbase
 - Fails to detect zero-day attacks

Statistical-based Anomaly Detection

- Do “past profile”
- Do “current profile”
- Calculate “anomaly score”
- If “anomaly score” > “some threshold”, then “generate an alarm”
 - Can detect zero-day attacks
 - Can be annoying

Machine Learning-based Anomaly Detections

- Bayesian networks
- Fuzzy logic
- Hidden Markov
- Neural networks
- Genetic algorithms
 - Knowing what is a normal profile or behavior, what could be abnormal
 - Involves training and learning, deviation from normal

Rule-Based Detection

- Many systems have used heuristic rules such as the following from NIDX (Bauer, '88):
 - Users should not read files in other users' personal directories
 - Users should not make copies of system programs
 - Users who log in after hours should use the same files they use during the day
 - Users must not write to other users files

Thresholds

- Statistical techniques are often approximated by **thresholds**, particularly when it isn't practical to develop full profiles or when speed is an issue.
 - **Threshold detection**: decide which events indicate intrusion independent of user.
 - Examples
 - running crack, copying password file, long machine strings.
 - Threshold detection is very commonly seen in conjunction with most other intrusion detection techniques.
 - Examples:
 - We might set cutoff for “expected” bad logins by one user at 3
 - We might set acceptable cutoff levels for network traffic, disk usage, or CPU usage

Statistical Detection

- In statistical anomaly detection, the standard technique is to gather behavior data and statistically examine behavior.
 - Can be used both for anomalies and for misuse; the difference is in how the data is used.
 - **Statistical anomaly detection:**
 - set up standards for what normal is, and a tolerance interval, and raise a warning when observations are *outside* that range.
 - **Statistical misuse detection:**
 - set up standards for what constitutes misuse, along with a tolerance interval, and if observations fall in that range then raise a warning.
 - Profiling, possibly of groups or categories rather than individuals, is commonly used in statistical detection.

Behavior Profiling

- Original concept:
 - Look at each audit record for user behavior
 - If a given record matched a rule, increase the associated user or system's suspicion rating
 - If the suspicion rating increases past a pre-set threshold, raise an alarm
- What is a behavior? It varies:
 - A particular action (reading a file)
 - A mapping from a command to an action (execute = execl, execl, /bin/sh)
 - A sequence of actions (copy file, change permissions)
 - A transition (from a "safe" state to an "unsafe" state)

Architectures: Some choices

- A non-exhaustive list of architectures for Network Systems:
 - Centralized
 - Generate audit records on all hosts on the network
 - Send/Copy records to a central location
 - Examine records
 - Distributed/Coordinated
 - Generate audit records on all hosts on the network
 - Process records locally
 - Send/Copy records to other locations
 - Distributed/Independent
 - Decisions are made independently although results may be shared
 - ** sometimes agent based

Port Scans

- Port Scan is often a prelude to an attack
 - Someone is investigating which network services are available on your machine
 - Looking for an old version of some daemon with unpatched buffer overflow?
- Port Scanning can be either “light” or detailed
 - Ping is among the simplest/mildest
 - Determine which services are “live”
 - Obtain version information about services
 - Target specific service versions

Detection

- Detection techniques used for these activities include
 - Collecting information about ping requests
 - Either host-based or network based - can be done at firewall
 - Usually rate/sequence/source dependent (partially to cut down on data storage costs)
- Stealth
 - Out of order target IP addresses
 - “low and slow” pings which do not go in sequence and which scan the network more slowly

Scanning Defense

- **Scan suppression**: block traffic from addresses that previously produced too many failed connection attempts.
- Use IDS
 - Requires network filtering and maintaining state
 - Can be subverted by slow scanning.

Honeypots and Honeyynet

- Acts as a decoy and collect information about attackers
 - Prosecution
 - Prevention